



Federal Financial Institutions Examination Council

FFIEC

Outsourcing
Technology Services

OT

JUNE 2004

IT EXAMINATION

HANDBOOK

Table of Contents

Introduction	1
Board and Management Responsibilities	2
Risk Management	3
Risk Assessment and Requirements	4
Quantity of Risk Considerations	5
Requirements Definition	6
Service Provider Selection	9
Request for Proposal	9
Due Diligence	10
Contract Issues	11
Service Level Agreements (SLAs)	15
Pricing Methods	16
Bundling	17
Contract Inducement Concerns	17
Ongoing Monitoring	18
Key Service Level Agreements and Contract Provisions	19
Financial Condition of Service Providers	20
General Control Environment of the Service Provider	21
Potential Changes due to the External Environment	22
Related Topics	22
Business Continuity Planning	22
Outsourcing the Business Continuity Function	24
Information Security/Safeguarding	26
Multiple Service Provider Relationships	26
Outsourcing to Foreign Service Providers	27
Appendix A: Examination Procedures	A-1
Appendix B: Laws, Regulations, and Guidance	B-1

Appendix C: Foreign-Based Third-Party Service Providers	C-1
Appendix D: Managed Security Service Providers	D-1

Introduction

The financial services industry has changed rapidly and dramatically. Advances in technology enable institutions to provide customers with an array of products, services, and delivery channels. One result of these changes is that financial institutions increasingly rely on external service providers for a variety of technology-related services. Generally, the term "outsourcing" is used to describe these types of arrangements.

The Federal Financial Institutions Examination Council (FFIEC) Information Technology Examination Handbook (IT Handbook) "Outsourcing Technology Services Booklet" (booklet) provides guidance and examination procedures to assist examiners and bankers in evaluating a financial institution's risk management processes to establish, manage, and monitor IT outsourcing relationships.

The ability to contract for technology services typically enables an institution to offer its customers enhanced services without the various expenses involved in owning the required technology or maintaining the human capital required to deploy and operate it. In many situations, outsourcing offers the institution a cost effective alternative to in-house capabilities. Outsourcing, however, does not reduce the fundamental risks associated with information technology or the business lines that use it. Risks such as loss of funds, loss of competitive advantage, damaged reputation, improper disclosure of information, and regulatory action remain. Because the functions are performed by an organization outside the financial institution, the risks may be realized in a different manner than if the functions were inside the financial institution resulting in the need for controls designed to monitor such risks.

Financial institutions can outsource many areas of operations, including all or part of any service, process, or system operation. Examples of information technology (IT) operations frequently outsourced by institutions and addressed in this booklet include: the origination, processing, and settlement of payments and financial transactions; information processing related to customer account creation and maintenance; as well as other information and transaction processing activities that support critical banking functions, such as loan processing, deposit processing, fiduciary and trading activities; security monitoring and testing; system development and maintenance; network operations; help desk operations; and call centers. The booklet addresses an institution's responsibility to manage the risks associated with these outsourced IT services.

Management may choose to outsource operations for various reasons. These include:

- Gain operational or financial efficiencies;
- Increase management focus on core business functions;
- Refocus limited internal resources on core functions;
- Obtain specialized expertise;
- Increase availability of services;
- Accelerate delivery of products or services through new delivery channels;

- Increase ability to acquire and support current technology and avoid obsolescence; and
- Conserve capital for other business ventures.

Outsourcing of technology-related services may improve quality, reduce costs, strengthen controls, and achieve any of the objectives listed previously. Ultimately, the decision to outsource should fit into the institution's overall strategic plan and corporate objectives.

Before considering the outsourcing of significant functions, an institution's directors and senior management should ensure such actions are consistent with their strategic plans and should evaluate proposals against well-developed acceptance criteria. The degree of oversight and review of outsourced activities will depend on the criticality of the service, process, or system to the institution's operation.

Financial institutions should have a comprehensive outsourcing risk management process to govern their technology service provider (TSP) relationships. The process should include risk assessment, selection of service providers, contract review, and monitoring of service providers. Outsourced relationships should be subject to the same risk management, security, privacy, and other policies that would be expected if the financial institution were conducting the activities in-house. This booklet primarily focuses on how the bank regulatory agencies review the risk management process employed by a financial institution when considering or executing an outsourcing relationship.

To help ensure financial institutions operate in a safe and sound manner, the services performed by TSPs are subject to regulation and examination. ^[1] The federal financial regulators have the statutory authority to supervise all of the activities and records of the financial institution whether performed or maintained by the institution or by a third party on or off of the premises of the financial institution. Accordingly, the examination and supervision of a financial institution should not be hindered by a transfer of the institution's records to another organization or by having another organization carry out all or part of the financial institution's functions. ^[2]

Many of the general principles on effective management of outsourcing relationships discussed in this booklet can and should be applied to managing the outsourcing of software development. Outsourcing of activities related to software development is addressed in the IT Handbook's, "Development and Acquisition Booklet."

This booklet rescinds and replaces Chapter 22 of the 1996 FFIEC Information Systems Examination Handbook, IS Servicing - Provider and Receiver.

Board and Management Responsibilities

Action Summary

The financial institution's board and senior management should establish and

approve risk-based policies to govern the outsourcing process. The policies should recognize the risk to the institution from outsourcing relationships and should be appropriate to the size and complexity of the institution.

The responsibility for properly overseeing outsourced relationships lies with the institution's board of directors and senior management. Although the technology needed to support business objectives is often a critical factor in deciding to outsource, managing such relationships is more than just a technology issue; it is an enterprise-wide corporate management issue. An effective outsourcing oversight program should provide the framework for management to identify, measure, monitor, and control the risks associated with outsourcing. The board and senior management should develop and implement enterprise-wide policies to govern the outsourcing process consistently. These policies should address outsourced relationships from an end-to-end perspective, including establishing servicing requirements and strategies; selecting a provider; negotiating the contract; and monitoring, changing, and discontinuing the outsourced relationship.

Factors institutions should consider include:

- Ensuring each outsourcing relationship supports the institution's overall requirements and strategic plans;
- Ensuring the institution has sufficient expertise to oversee and manage the relationship;
- Evaluating prospective providers based on the scope and criticality of outsourced services;
- Tailoring the enterprise-wide, service provider monitoring program based on initial and ongoing risk assessments of outsourced services; and
- Notifying its primary regulator regarding outsourced relationships, when required by that regulator.^[3]

The time and resources devoted to managing outsourcing relationships should be based on the risk the relationship presents to the institution. To illustrate, outsourcing processing of a small credit card portfolio will require a different level of oversight than outsourcing processing of all loan applications. Additionally, smaller and less complex institutions may have less flexibility than larger institutions in negotiating for services that meet their specific needs and in monitoring their service providers.

Risk Management

Risk management is the process of identifying, measuring, monitoring, and managing risk. Risk exists whether the institution maintains information and technology services internally or elects to outsource them. Regardless of which alternative they choose, management is responsible for managing risk in all outsourcing relationships. Accordingly, institutions should establish and maintain an effective risk management process for initiating and overseeing all outsourced operations.

An effective risk management process involves several key factors:

- Establishing senior management and board awareness of the risks associated with outsourcing agreements in order to ensure effective risk management practices;
- Ensuring that an outsourcing arrangement is prudent from a risk perspective and consistent with the business objectives of the institution;
- Systematically assessing needs while establishing risk-based requirements;
- Implementing effective controls to address identified risks;
- Performing ongoing monitoring to identify and evaluate changes in risk from the initial assessment; and
- Documenting procedures, roles/responsibilities, and reporting mechanisms.

Typically, this process incorporates the following activities:

- Risk assessment and requirements definition;
- Due diligence in selecting a service provider;
- Contract negotiation and implementation; and
- Ongoing monitoring.

The preceding comments focus on risk elements specifically associated with outsourcing. For a broader perspective on IT transactional and operational risk, refer to the IT Handbook's "Supervision of Technology Service Providers (TSP) Booklet," which addresses outsourcing risk from the service provider perspective.

Risk Assessment and Requirements

<i>Action Summary</i>

Management should:

- Assess the risk from outsourcing;
- Involve stakeholders in creating risk-based written requirements to control an outsourcing action; and
- Use the written requirements to guide and manage the remainder of the outsourcing process.

Outsourced IT services can contribute to operational risks (also referred to as transaction risks). Operational risk may arise from fraud, error, or the inability to deliver products or services, maintain a competitive position, or manage information. It exists in each process involved in the delivery of the financial institutions' products or services. Operational risk not only includes operations and transaction processing, but also areas such as customer service, systems development and support, internal control processes, and capacity and contingency planning. Operational risk also may affect other risks such as interest rate, compliance, liquidity, price, strategic, or reputation risk as described below.

- Reputation risk-Errors, delays, or omissions in information technology that become public knowledge or directly affect customers can significantly affect the reputation of the serviced financial institutions. For example, a TSP's failure to maintain adequate business resumption plans and facilities for key processes may impair the ability of serviced financial institutions to provide critical services to their customers.
- Strategic risk-Inadequate management experience and expertise can lead to a lack of understanding and control of key risks. Additionally, inaccurate information from TSPs can cause the management of serviced financial institutions to make poor strategic decisions.
- Compliance (legal) risk-Outsourced activities that fail to comply with legal or regulatory requirements can subject the institution to legal sanctions. For example, inaccurate or untimely consumer compliance disclosures or unauthorized disclosure of confidential customer information could expose the institution to civil money penalties or litigation. TSPs often agree to comply with banking regulations, but their failure to track regulatory changes could increase compliance risk for their serviced financial institutions.
- Interest rate, liquidity, and price (market) risk-Processing errors related to investment income or repayment assumptions could lead to unwise investment or liquidity decisions thereby increasing market risks.

Quantity of Risk Considerations

The quantity of risk associated with an outsourced IT service is subject to the function outsourced, the service provider, and the technology used by the service provider. Management should consider the following factors in evaluating the quantity of risk at the inception of an outsourcing decision.

- Risks pertaining to the function outsourced include:
 - Sensitivity of data accessed, protected, or controlled by the service provider;
 - Volume of transactions; and
 - Criticality to the financial institution's business.
- Risks pertaining to the service provider include:
 - Strength of financial condition;
 - Turnover of management and employees;
 - Ability to maintain business continuity;
 - Ability to provide accurate, relevant, and timely Management Information Systems (MIS);
 - Experience with the function outsourced;
 - Reliance on subcontractors;
 - Location, particularly if cross-border (See Appendix C, Foreign-Based Third-Party Service Providers); and
 - Redundancy and reliability of communication lines.
- Risks pertaining to the technology used include:
 - Reliability;
 - Security; and
 - Scalability to accommodate growth.

Requirements Definition

The definition of business requirements sets the stage for all outsourcing actions and forms the basis for subsequent management of the outsourced activity. The requirements are developed through a process that identifies the functions or activities to be outsourced, assesses the risk of outsourcing those functions or activities, and establishes a baseline from which appropriate control measures can be identified. These requirements provide a basis for an understanding between the financial institution and the service provider as to what the risks are and how they will be managed and controlled.

Key Practices

Sound practices for the development of requirements include:

- Stakeholder involvement-All organizational groups who will be directly involved with the service provider or in using the contracted service should be represented in the development of product and service requirements.
- Integration-The development should result in requirements that support the subsequent steps of solicitation, selection, contracting, and monitoring.
- Documentation-Documentation will greatly assist in ensuring that the service contracted and delivered meets the institution's requirements. Documentation will also allow for subsequent reviews of the processes' adequacy and integrity.

Components

The requirements definition phase should result in a detailed document containing descriptions of the institution's expectations relative to the outsourced service. The requirements document may consider, but is not limited by, the following high level topical components:

- Scope and nature
 - Service description;
 - Technology; and
 - Customer support.
- Standards and service levels
 - Availability and performance;
 - Change management;
 - Financial reporting;
 - Quality of service;
 - Security; and
 - Business continuity.
- Minimum acceptable service provider characteristics
 - Industry experience;
 - Management experience;
 - Technology and systems architecture;